STUDENTE: SIMONE MEOLA

Report di Penetration Testing: Estrazione e Cracking delle Credenziali su DVWA

1. Obiettivo e Ambiente di Laboratorio

L'attività svolta ha avuto come obiettivo la simulazione di un attacco di esfiltrazione e cracking delle password ai danni dell'applicazione web vulnerabile **DVWA (Damn Vulnerable Web App)** all'interno di un ambiente di laboratorio controllato.

- **Macchina Attaccante:** Kali Linux eseguita su Oracle VirtualBox.
- **Sistema Target:** Server remoto all'indirizzo IP `192.168.56.102` ospitante il database MySQL/MariaDB di DVWA.
- **Strumenti Utilizzati:** Client da riga di comando `mysql`, editor di testo `nano` e tool di password cracking `John the Ripper`.

2. Fasi Operative Eseguite

Fase 1: Connessione al Database ed Esfiltrazione degli Hash

Inizialmente è stato effettuato un tentativo di connessione remota al database MySQL come utente `root` tramite il comando `mysql -h 192.168.56.102 -u root`, che ha restituito l'errore `ERROR 2026 (HY000): TLS/SSL error: wrong version number`. L'incompatibilità nella negoziazione del protocollo cifrato è stata superata aggiungendo l'opzione `--skip-ssl`.

Una volta ottenuto l'accesso al DBMS MariaDB, è stato selezionato il database applicativo (`USE dvwa;`) ed eseguita una query sulla tabella degli utenti (`SELECT User, password FROM users;`), estraendo 5 record contenenti i nomi utente e le rispettive password cifrate con algoritmo **MD5**.

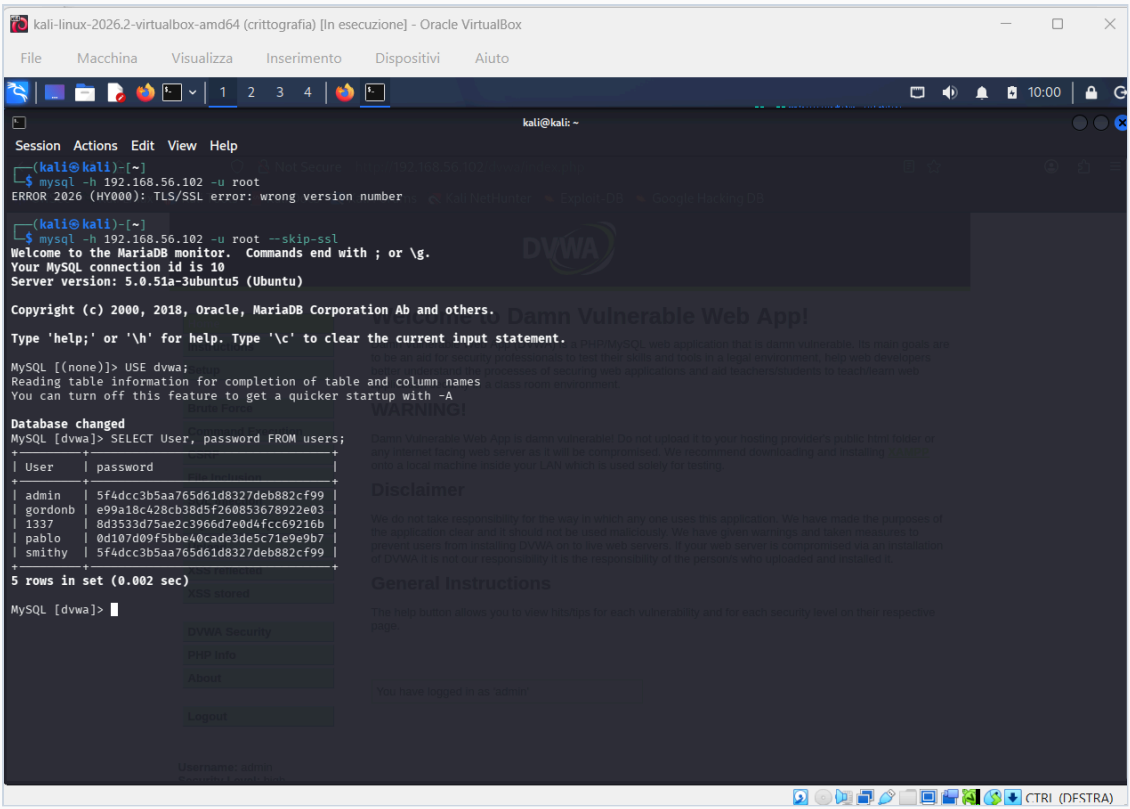


Figura 1 — Connessione remota al DBMS con --skip-ssl ed esfiltrazione dei 5 record dalla tabella dvwa.users.

Fase 2: Preparazione e Formattazione del File di Input

Gli hash estratti sono stati salvati sul sistema Kali Linux all'interno del file di testo `hashes.txt` tramite l'editor `nano`. Per consentire a John the Ripper di associare in modo chiaro ogni password in chiaro al rispettivo account durante la fase di visualizzazione, i dati sono stati strutturati secondo la sintassi standard `utente:hash`:

```
admin:5f4dcc3b5aa765d61d8327deb882cf99
gordonb:e99a18c428cb38d5f260853678922e03
1337:8d3533d75ae2c3966d7e0d4fcc69216b
pablo:0d107d09f5bbe40cade3de5c71e9e9b7
smithy:5f4dcc3b5aa765d61d8327deb882cf99
```

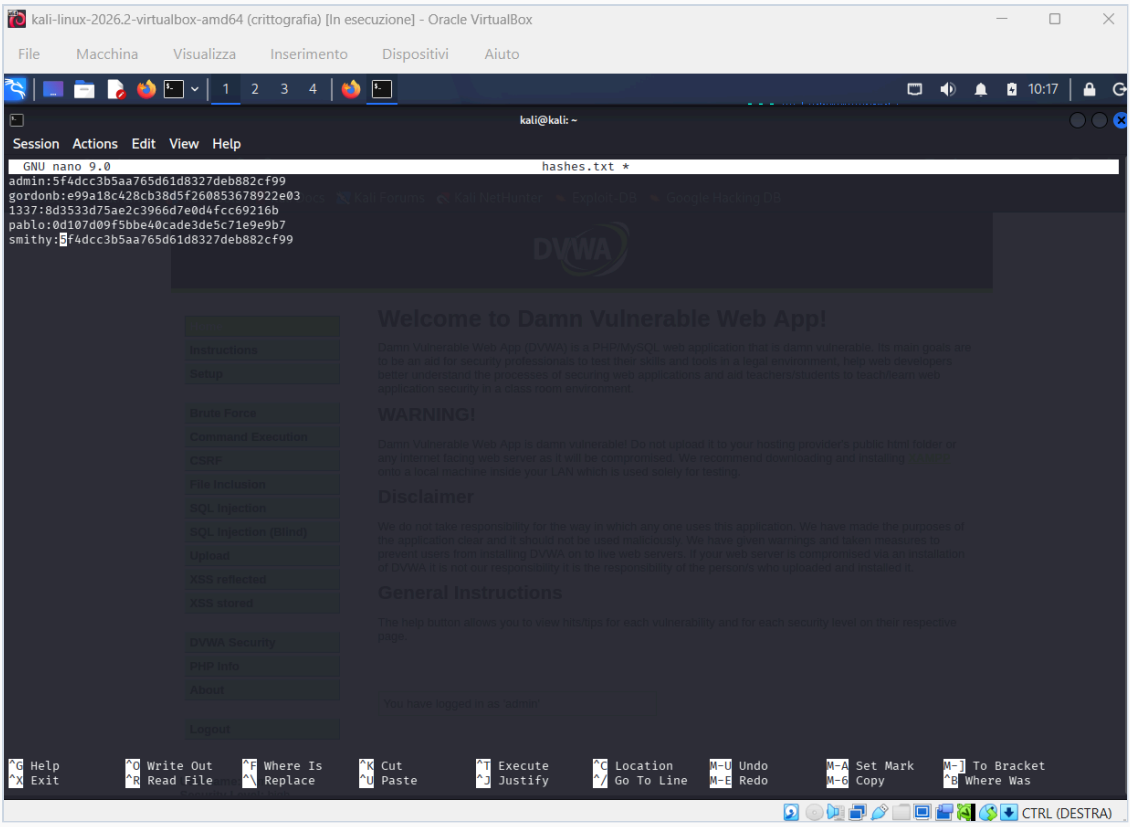


Figura 2 — Salvaguardia e formattazione delle credenziali nel file hashes.txt tramite l'editor GNU nano.

Fase 3: Cracking tramite John the Ripper

Poiché l'esecuzione predefinita di John tende a rilevare erroneamente le stringhe esadecimali MD5 grezze come hash Windows `LM`, è stato necessario forzare esplicitamente il formato corretto tramite il flag `--format=raw-md5`:

```
john --format=raw-md5 hashes.txt
```

Il software ha caricato gli hash ed eseguito una combinazione di attacco a dizionario (utilizzando la wordlist predefinita `/usr/share/john/password.lst`) e modalità incrementale (`ASCII`), individuando le password in chiaro in tempi immediati.

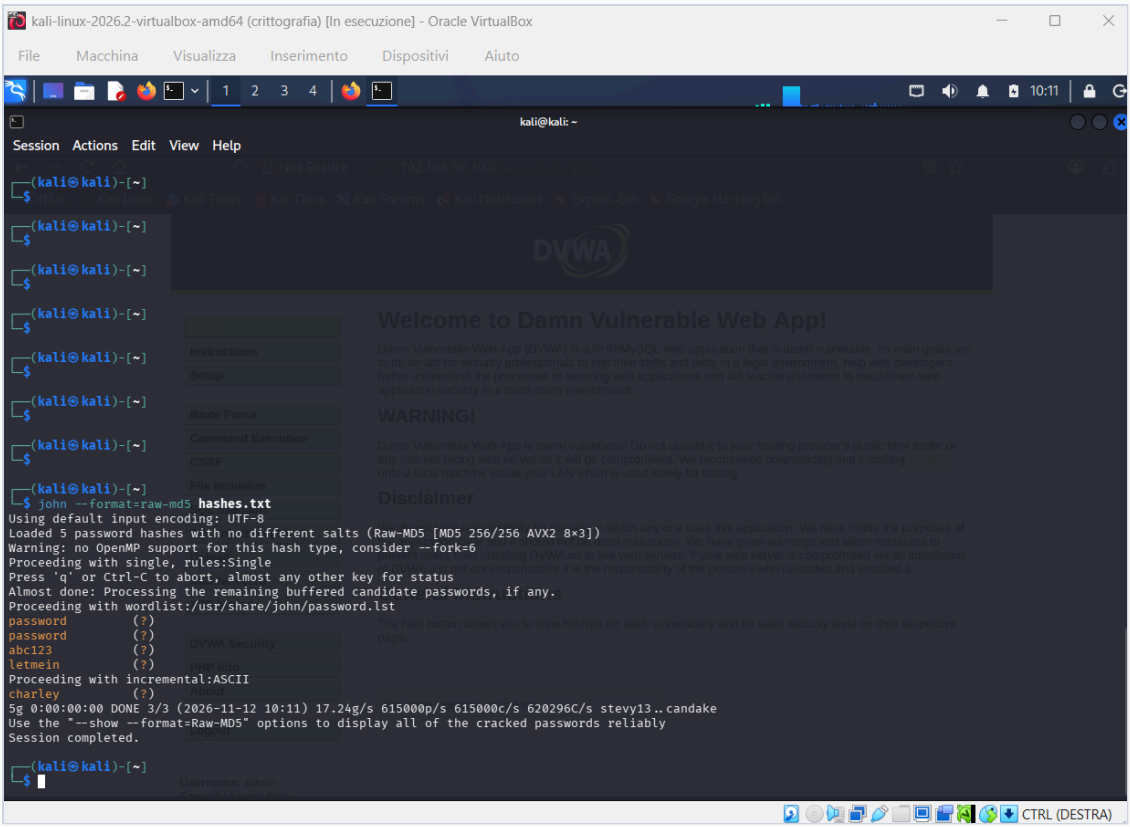


Figura 3 — Avvio della sessione di cracking con formato raw-md5 e individuazione delle password in chiaro.

Al termine dell'elaborazione, i risultati sono stati richiamati a schermo utilizzando l'opzione di visualizzazione:

```
john --show --format=raw-md5 hashes.txt
```

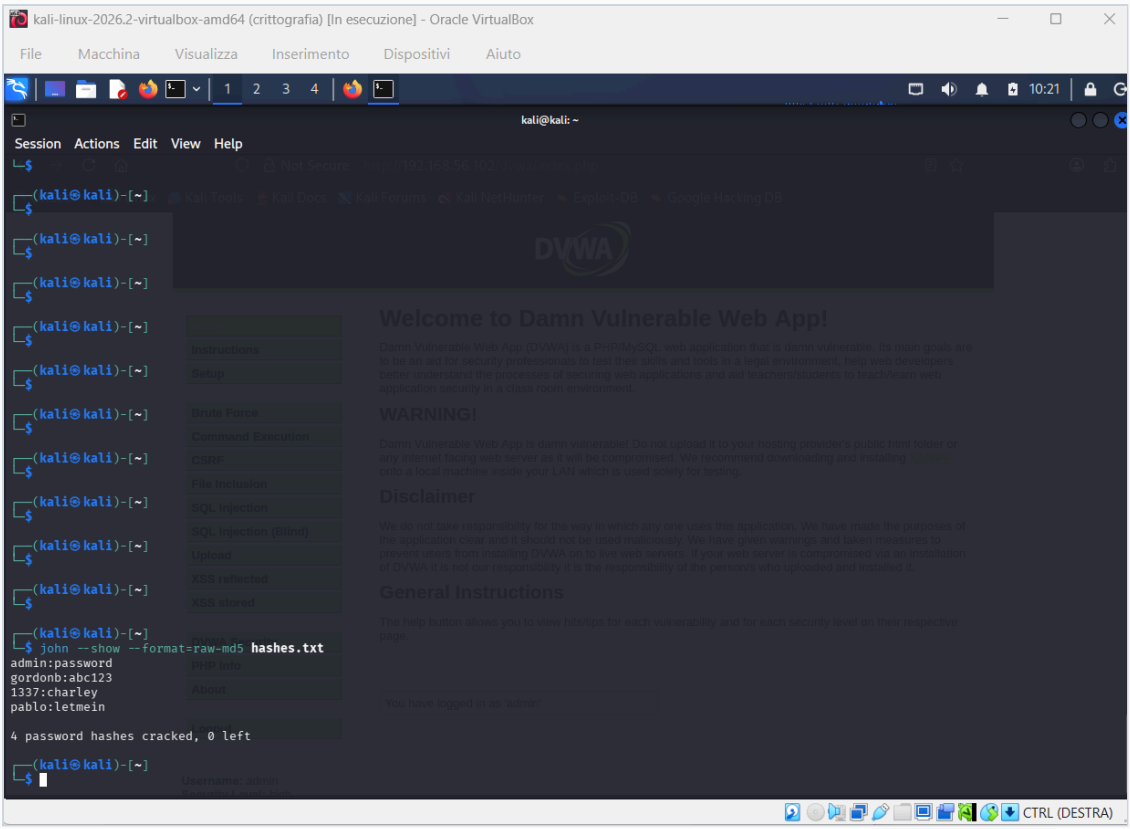


Figura 4 — Visualizzazione delle password decifrate associate ai rispettivi nomi utente tramite john --show.

3. Risultati Ottenuti

L'attività di analisi ha permesso di ricostruire integralmente tutte e 5 le coppie di credenziali presenti nel database dell'applicazione:

Utente	Hash MD5 Estratto	Password in Chiaro
admin	`5f4dcc3b5aa765d61d8327deb882cf99`	`password`
gordonb	`e99a18c428cb38d5f260853678922e03`	`abc123`
1337	`8d3533d75ae2c3966d7e0d4fcc69216b`	`charley`
pablo	`0d107d09f5bbe40cade3de5c71e9e9b7`	`letmein`
smithy	`5f4dcc3b5aa765d61d8327deb882cf99`	`password`

4. Analisi Tecnica: Omissione dell'Ultimo Hash nel Comando `--show`

Osservando la Figura 4, si rileva che il comando `john --show --format=raw-md5 hashes.txt` restituisce esattamente **4 righe** (`4 password hashes cracked, 0 left`), omettendo l'utente `smithy` nonostante nel file di input fossero state inserite 5 righe distinte.

> **Spiegazione del comportamento:** L'omissione non indica un fallimento nel cracking del quinto account, bensì deriva dalla combinazione tra una vulnerabilità crittografica del database e il funzionamento interno di John the Ripper.

- **Assenza di Salting nel Database:** L'applicazione DVWA calcola l'hash MD5 direttamente sulla password dell'utente senza concatenare alcuna stringa casuale univoca (*salt*). Poiché sia `admin` sia `smithy` utilizzano la medesima password (`password`), la funzione deterministica MD5 genera per entrambi lo stesso identico digest esadecimale: `5f4dcc3b5aa765d61d8327deb882cf99`.
- **Deduplicazione Interna di John the Ripper:** Per ottimizzare l'allocazione di memoria ed evitare calcoli ridondanti sullo stesso valore crittografico, John the Ripper rimuove automaticamente gli hash duplicati in fase di caricamento. Inoltre, nel proprio file di registro interno (`~/.john/john.pot`), il tool memorizza esclusivamente le coppie univoche `hash:password` prive del nome utente. Di conseguenza, durante l'esecuzione di `--show`, il programma associa l'hash craccato alla prima occorrenza incontrata nel file sorgente (`admin:password`) e ignora i duplicati successivi, rendendo comunque immediata l'attribuzione della stessa password all'account `smithy`.

5. Raccomandazioni di Sicurezza (Remediation)

Per mitigare le vulnerabilità riscontrate durante il laboratorio e proteggere adeguatamente le credenziali degli utenti, si raccomandano le seguenti misure correttive:

- **Dismissione dell'algoritmo MD5:** Sostituire MD5 (ormai obsoleto, eccessivamente veloce da calcolare e vulnerabile ad attacchi a dizionario e collisioni) con funzioni di derivazione delle chiavi moderne e computazionalmente lente, quali **Argon2id**, **bcrypt** o **PBKDF2**.
- **Implementazione del Salting:** Generare un *salt* crittograficamente casuale e univoco per ogni singolo utente prima dell'hashing, garantendo che password identiche producano digest completamente differenti nel database.
- **Rafforzamento delle Password Policy e del DBMS:** Imporre criteri minimi di lunghezza e complessità per impedire l'uso di password banali (`password`, `abc123`), disabilitare l'accesso remoto per l'utenza amministrativa `root` di MySQL e configurare correttamente i certificati TLS/SSL sul server database.